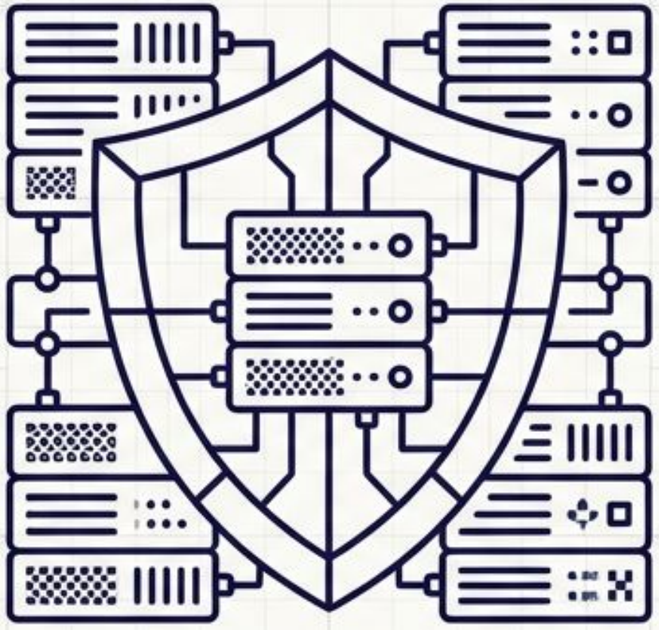


Threat Modeling Case Study: E-Commerce Plattform

Eine methodische Sicherheitsanalyse der eBay-Architektur inkl. STRIDE, Asset-Identifikation und Defense-in-Depth-Strategie.

Autor: Sándor Barnabás
Projektart: Security Architecture Portfolio

Akademische Validierung:
Ausgezeichnet (30/30 Punkte)

NotebookLM

Zielsetzung (Das Problem)

- Entwicklung eines umfassenden, praxisnahen Threat Models für eine komplexe, transaktionsstarke E-Commerce-Plattform.
- Fokus auf Datensicherheit, Systemverfügbarkeit und Schutz vor Finanzbetrug in einer verteilten Architektur.

Methodik (Der Ansatz)

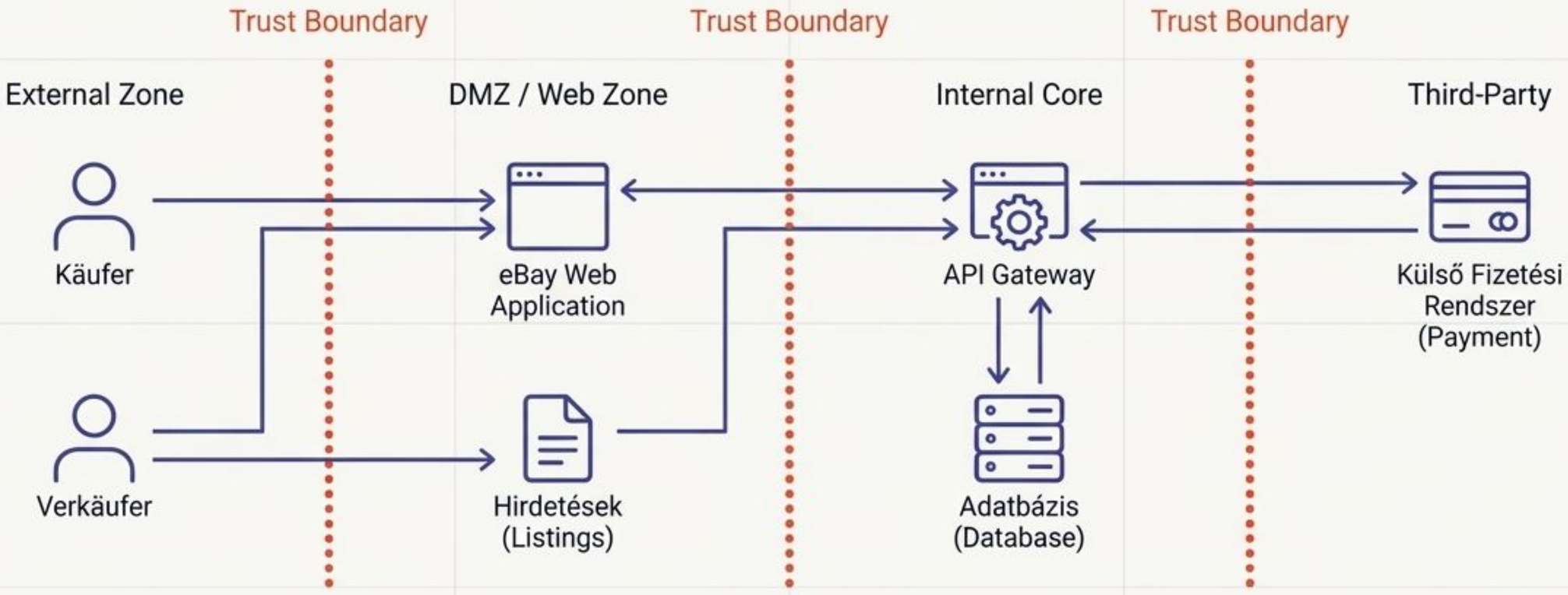
- Nutzung von Data Flow Diagrams (DFDs) zur Modellierung.
- Definition strikter Trust Boundaries zur Segmentierung.
- Kategorisierung aller Angriffsvektoren nach dem etablierten Microsoft STRIDE-Framework.

Ergebnis (Der Impact)

- Identifikation hochkritischer Schwachstellen (RCE, SQLi, Account Takeover).
- Design einer robusten, mehrschichtigen Defense-in-Depth-Strategie (WAF, CDN, MFA).
- Validiert mit maximaler akademischer Punktzahl (30/30) für exzellt (30/30) für exzellentes architektonisches Denken.

NotebookLM

Systemarchitektur & Scope



Die Implementierung von Trust Boundaries visualisiert exakt, an welchen Schnittstellen Datenpakete ihren Vertrauensstatus ändern und zwingend validiert werden müssen.

NotebookLM

Identifikation der kritischen Assets

Transaktionsdaten

Höchstes Geschäftsrisiko

Zahlungsströme, externe Zahlungsschnittstellen und finanzielle Rückabwicklungen. Ein Kompromiss hat direkten, katastrophalen Impact auf den Unternehmensumsatz.

Nutzeridentitäten

Haupt-Angriffsvektor

Accounts von Käufern und Verkäufern. Das kritischste Ziel für Phishing-Kampagnen, Social Engineering und Account Takeover (ATO) zur Betrugsabwicklung.

Infrastruktur & APIs

Verfügbarkeitsrisiko

Web-Server, API-Endpunkte und externe Schnittstellen. Müssen zwingend gegen Volumentraffic (DDoS) und unautorisierte Token-Nutzung gehärtet sein.

Kern-Datenbank

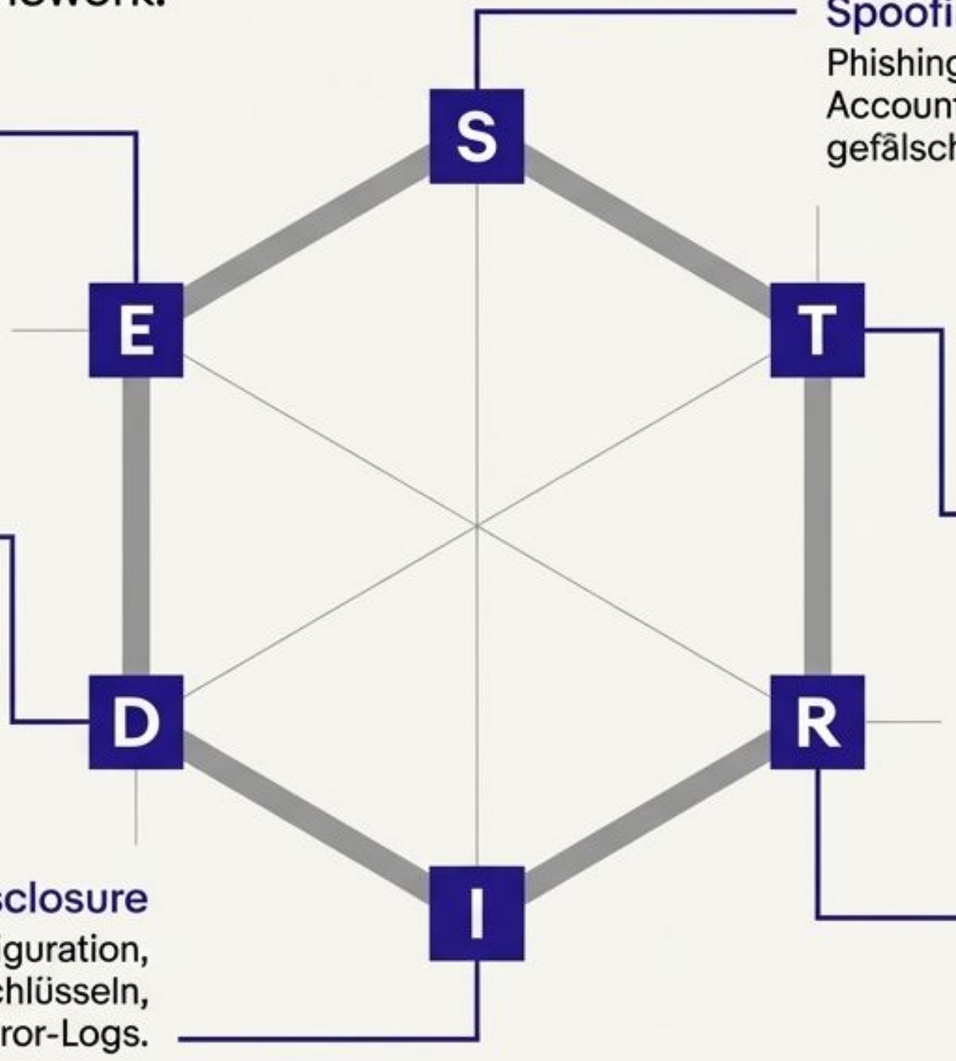
Integritätsrisiko

Persistente Speicherung sensibler Nutzer-, Listing- und Konfigurationsdaten. Das primäre Ziel von SQL-Injections, Exfiltration und Ransomware-Verschlüsselung.

NotebookLM

Die Bedrohungslandschaft: STRIDE-Synthese

Mapping der eBay-spezifischen Vektoren auf das Industrie-Standard-Framework.



Spoofing
Phishing von Käufern/Verkäufern, Account Takeover (Kontoübernahme), gefälschte Zahlungsbestätigungen.

Tampering
SQL-Injection in der Datenbank, Manipulation von Listings, inkonzistente Replikation.

Repudiation
Token-Diebstahl, unautorisierte API-Aufrufe ohne ausreichende Audit-Logs, falsche Käuferbeschwerden.

Information Disclosure
Datenabfluss durch Fehlkonfiguration, Leak von sensiblen API-Schlüsseln, Auslesen von Error-Logs.

Denial of Service
DDoS-Angriffe auf die Webserver, API-Überlastung durch Botnetze (Rate Limiting Bypass).

Elevation of Privilege
Remote Code Execution (RCE) auf dem Server, Ransomware-Ausbreitung intern.

NotebookLM

Angriffsvektor I: Client & Identity

Der Angriffsvektor (Vulnerabilities)

Fokus: Käufer & Verkäufer

- Gezielte Phishing-Kampagnen zur Erbeutung von Login-Daten.
- Social Engineering Angriffe über das interne eBay-Nachrichtensystem.
- Account Takeover (ATO) für massenhaften Betrug mit gefälschten Angeboten.
- Initiierung unautorisierter Zahlungsrückabwicklungen.

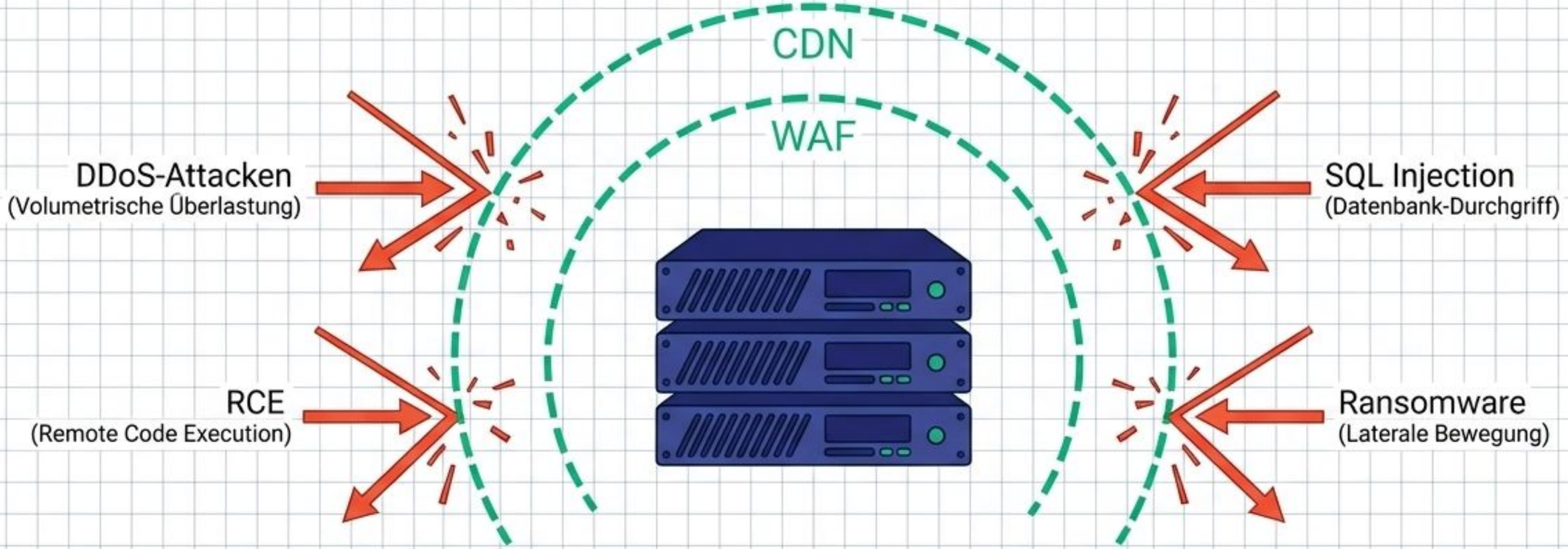
Die Architektur-Lösung (Mitigations)

Fokus: Identity & Access Management

- Zwingende Implementierung von MFA (Multi-Factor Authentication) für alle Accounts.
- Strikte E-Mail-Authentifizierung (SPF, DKIM, DMARC) gegen Spoofing-Versuche.
- Automatisierte Verhaltensüberwachung (z.B. Login von neuem Gerät + sofortige Massen-Listings führt zur Sperre).
- Integrierte Link-Validierung im internen Nachrichtensystem.

NotebookLM

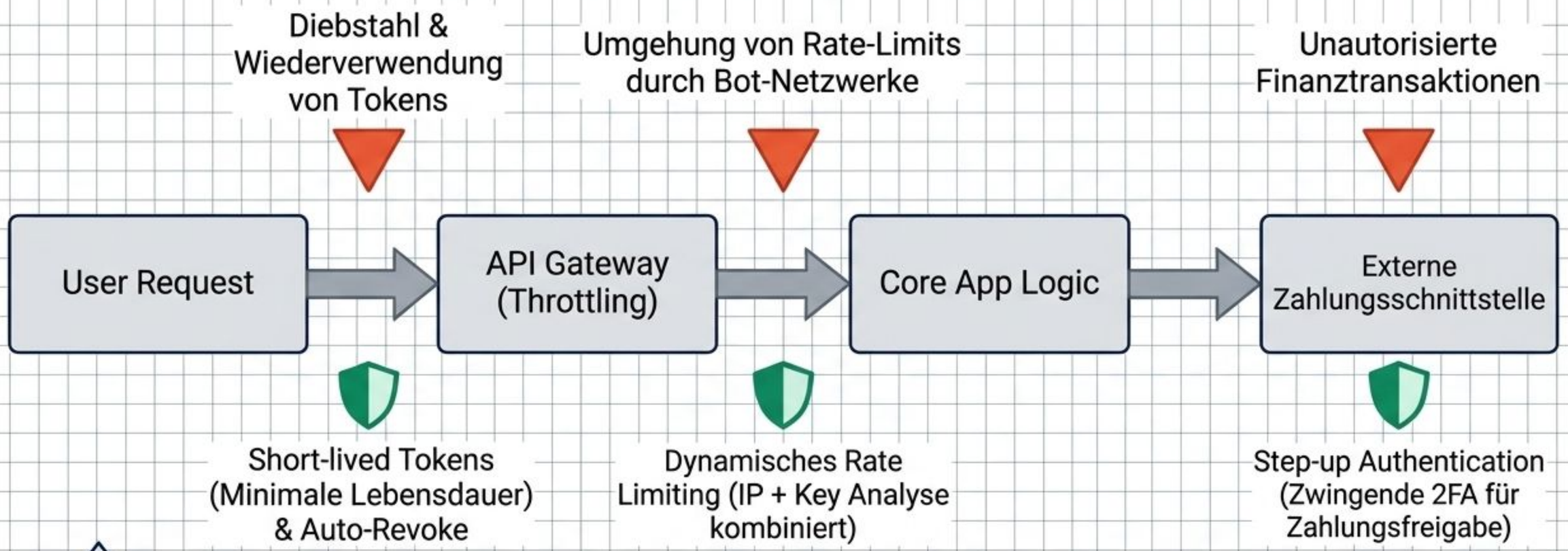
Angriffsvektor II: Application & Infrastructure



Edge-Schutz (CDN)	Applikations-Schutz (WAF)	Datenbank-Härtung
Verteiltes Content Delivery Network zur Lastaufnahme und Filterung von Volumentraffic am Rand des Netzwerks.	Web Application Firewall blockiert bösartige Payloads (SQLi, XSS) vor Erreichen der eigentlichen Applikationslogik.	Konsequente Nutzung parametrisierter Abfragen und strikte Durchsetzung des Principle of Least Privilege.

NotebookLM

Angriffsvektor III: API & External Integrations



Fazit: Externe Schnittstellen erfordern eine Entkopplung von Vertrauen. Jede Transaktion muss kryptografisch validiert und ratenlimitiert werden.

NotebookLM

Die Architektur-Festung: Defense-in-Depth

Synergetisches Zusammenwirken der Schutzschichten.

Layer 1 - Network Edge (Verfügbarkeit)

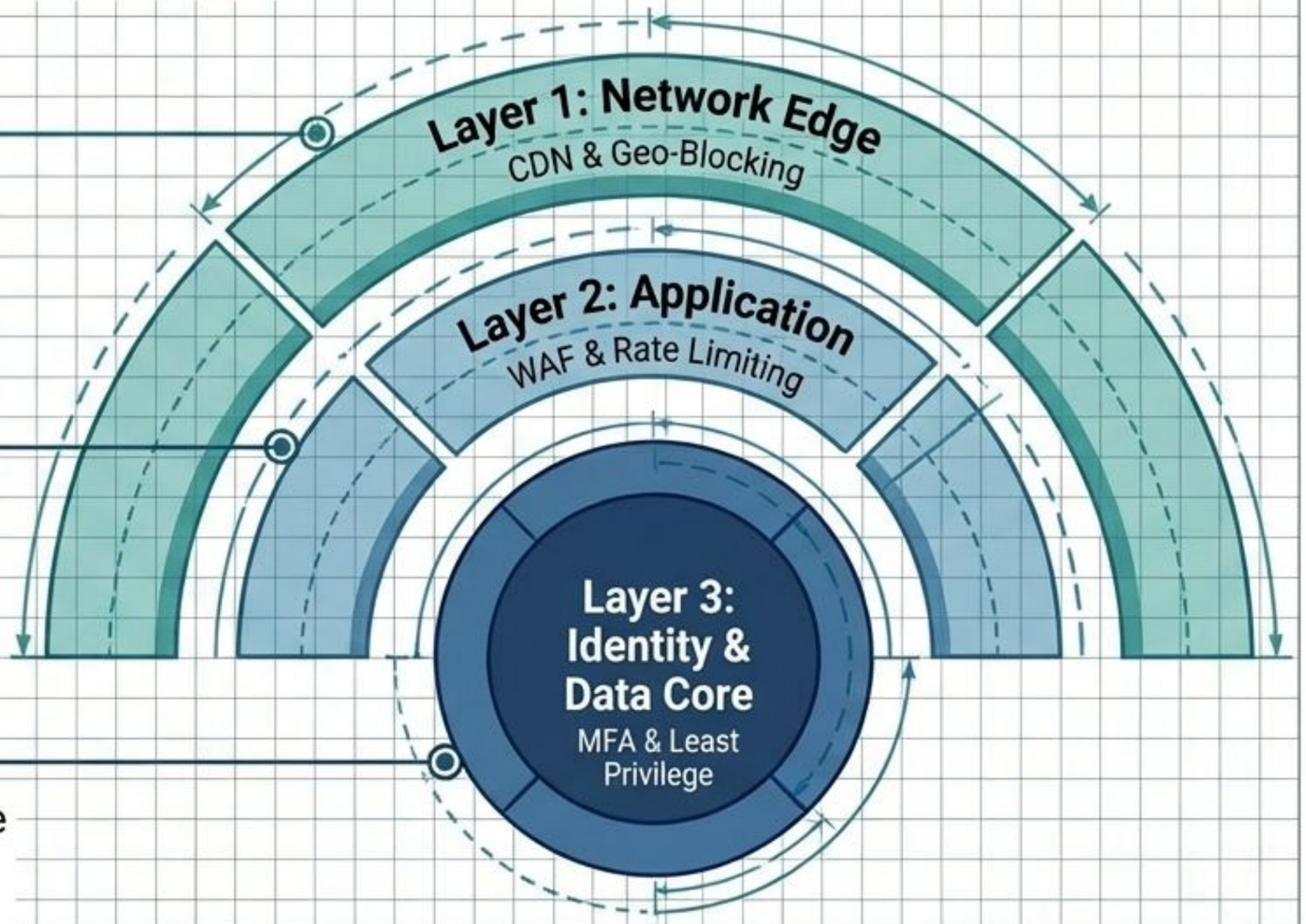
Technologie: CDN & Geo-Blocking. Absorbiert massive DDoS-Angriffe und blockiert bekannte Botnetz-IPs, lange bevor sie das Rechenzentrum erreichen.

Layer 2 - Application Layer (Integrität)

Technologie: Web Application Firewall (WAF) & Rate Limiting. Inspiziert den HTTP/HTTPS-Traffic tiefgehend. Blockt SQLi, RCE-Versuche und drosselt unnatürliches API-Verhalten.

Layer 3 - Identity Core (Vertraulichkeit)

Technologie: MFA, Least Privilege & Parametrisierte Queries. Schützt die Kern-Daten selbst dann, wenn Perimeter-Schichten durchbrochen wurden oder Zugangsdaten kompromittiert sind.



NotebookLM

Vulnerability vs. Mitigation Matrix

Executive Summary der Architektur-Kontrollen.

Kritisches Asset	STRIDE-Kategorie	Spezifische Bedrohung	Architektur-Mitigation
User Account	Spoofing	Account Takeover / Phishing	MFA, DMARC, Device-Tracking
Web-Server	Denial of Service	DDoS, Botnet-Überlastung	CDN, Geo-Blocking, Bot-Detection
App-Logik	Elevation of Privilege	RCE (Schadcode-Ausführung)	WAF, Input-Validierung
API-Gateway	Repudiation	Token-Klau, Rate Limit Bypass	Dynamisches Throttling, Short-lived Tokens
Kern-Datenbank	Tampering	SQL Injection, Daten-Manipulation	Parametrisierte Queries, Least Privilege

NotebookLM

Akademische Validierung & Experten-Feedback

30 / 30

Maximale Punktzahl
Ausgezeichnete Bewertung

> *Die Nutzung von Trust Boundaries und die klare Visualisierung der Datenflüsse im Modell bieten einen eindeutigen professionellen Mehrwert.*

> *Die identifizierten Bedrohungen (Account Takeover, Token-Klau, DDoS, SQLi, RCE) und Mitigationen (MFA, WAF, CDN) sind technisch präzise und realistisch.*

> *Es ist offensichtlich, dass hier tiefgreifend in Architekturen gedacht und die Systematik verstanden wird, anstatt nur Standard-OWASP-Themen aufzuzählen. Eine sehr starke, durchdachte Arbeit.*

NotebookLM

Fazit & Ausblick (Roadmap)

Zusammenfassung

Erfolgreiche Transformation einer komplexen E-Commerce-Umgebung in ein strukturiertes Threat Model.

Verankerung von ‘Security by Design’ durch den konsequenten Einsatz von Trust Boundaries und einer Defense-in-Depth-Architektur.

Zukunft: Bedrohungsbewertung nicht nur nach technischem Schweregrad (CVSS), sondern nach finanziellem Risiko (Risk = Probability × Impact).

Umsetzung des Experten-Feedbacks: Einführung einer quantitativen Business Impact Priorisierung.

Status Quo: Technisches Threat Modeling & Mitigation Design.

Dokumentation: Vollständiges Repository auf GitHub ansehen

Kontakt: Sándor Barnabás | Security Architecture Portfolio

NotebookLM